

Sécurisation Réseau

Mise en place de la politique de sécurité réseau
pour une PME de 45 collaborateurs

Cours : PROJET FIL ROUGE – INFRA SI

Auteur : Sriram MALLIPOUDY

Année universitaire : 2025–2028

Document à usage pédagogique

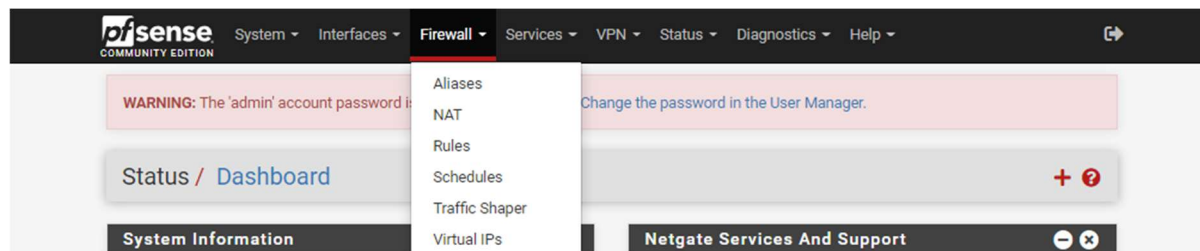
Table des matières

1. Firewall – Configuration et règles de filtrage.....	3
1.1 Interface LAN_ADMIN.....	3
1.2 Interface LAN_EMP	4
1.3 Interface LAN_SRV	5
1.4 Interface DMZ	6
1.5 NAT – Port Forward.....	7
2. Journalisation.....	8
2.1 Éléments journalisés	8
3. Politique de mots de passe	9
3.1 Règles applicables	9
3.2 Comptes définis et conformité	9
4. Justification des choix de sécurité	10
4.1 Refus par défaut (Default Deny)	10
4.2 Isolation des zones réseau	10
4.3 Accès administrateur restreint	10
4.4 Journalisation systématique	10
4.5 Politique de mots de passe robuste.....	10

1. Firewall – Configuration et règles de filtrage

Le pare-feu pfSense constitue le point central de la sécurisation réseau. Il assure le filtrage de l'ensemble du trafic entre les zones LAN, DMZ et WAN. Sa configuration repose sur un principe de refus par défaut : tout trafic non explicitement autorisé est bloqué.

Les règles sont gérées depuis l'interface Web de pfSense, sous le menu Firewall > Rules. La capture ci-dessous montre le menu de navigation :



1.1 Interface LAN_ADMIN

Le réseau d'administration bénéficie d'un accès étendu permettant la gestion de l'ensemble de l'infrastructure. Une règle Anti-Lockout Rule empêche tout verrouillage accidentel de l'interface pfSense. L'accès SSH vers le Bastion (port 2222), la navigation web (HTTP/HTTPS), le DNS et le NTP sont autorisés. Tout trafic résiduel est bloqué.

Rules (Drag to Change Order)											
	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
☒	0/557 KiB	*	*	*	LAN_ADMIN Address	443, 80	*	*		Anti-Lockout Rule	
☐	0/0 B	IPv4 TCP	LAN_ADMIN subnets	*	192.168.40.14	2222	*	none		SSH LAN_ADMIN to Bastion	
☐	0/62 KiB	IPv4 TCP	LAN_ADMIN subnets	*	*	80 (HTTP)	*	none			
☐	2/108.68 MiB	IPv4 TCP	LAN_ADMIN subnets	*	*	443 (HTTPS)	*	none			
☐	0/46 KiB	IPv4 UDP	LAN_ADMIN subnets	*	*	53 (DNS)	*	none			
☐	0/0 B	IPv4 UDP	LAN_ADMIN subnets	*	*	123 (NTP)	*	none			
☐	0/0 B	IPv4 ICMP any	LAN_ADMIN subnets	*	*	*	*	none			
☐	0/0 B	IPv4 *	LAN_ADMIN subnets	*	LAN_EMP subnets	*	*	none			
☐	0/31 KiB	IPv4 TCP	LAN_ADMIN subnets	*	*	*	*	none			

Protocole	Source	Destination / Port	Description
IPv4 *	LAN_ADMIN Address	443, 80	Anti-Lockout Rule (accès pfSense Web)
IPv4 TCP	LAN_ADMIN subnets	192.168.40.14 : 2222	SSH LAN_ADMIN vers Bastion
IPv4 TCP	LAN_ADMIN subnets	* : 80 (HTTP)	Navigation web HTTP
IPv4 TCP	LAN_ADMIN subnets	* : 443 (HTTPS)	Navigation web HTTPS
IPv4 UDP	LAN_ADMIN subnets	* : 53 (DNS)	Résolution DNS

Protocole	Source	Destination / Port	Description
IPv4 UDP	LAN_ADMIN subnets	* : 123 (NTP)	Synchronisation horloge
IPv4 ICMP	LAN_ADMIN subnets	*	Ping (diagnostic réseau)
IPv4 *	LAN_ADMIN subnets	LAN_EMP subnets	Accès admin vers réseau employés
IPv4 TCP [BLOCK]	LAN_ADMIN subnets	*	Blocage du reste

1.2 Interface LAN_EMP

Les employés disposent d'un accès Internet limité (HTTPS, DNS, NTP). L'accès direct aux réseaux LAN_SRV et LAN_ADMIN est strictement bloqué afin de prévenir tout mouvement latéral non autorisé. L'accès à l'interface d'administration pfSense est également interdit.

Un accès HTTP/HTTPS spécifique vers le Web Server situé en DMZ (192.168.40.10) est autorisé pour permettre l'utilisation de l'application interne par les employés. Tout autre accès vers la DMZ reste bloqué.

Rules (Drag to Change Order)											
☐	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
☐		0/0 B	IPv4 TCP	LAN_EMP subnets	*	This Firewall (self)	80 (HTTP)	*	none		
☐		0/0 B	IPv4 TCP	LAN_EMP subnets	*	This Firewall (self)	443 (HTTPS)	*	none		
☐		0/0 B	IPv4 TCP	LAN_EMP subnets	*	192.168.40.14	2222	*	none		
☐		0/0 B	IPv4 TCP	LAN_EMP subnets	*	*	443 (HTTPS)	*	none		
☐		0/0 B	IPv4 UDP	LAN_EMP subnets	*	*	53 (DNS)	*	none		
☐		0/0 B	IPv4 UDP	LAN_EMP subnets	*	*	123 (NTP)	*	none		
☐		0/0 B	IPv4 *	LAN_EMP subnets	*	LAN_SRV subnets	*	*	none		
☐		0/0 B	IPv4 *	LAN_EMP subnets	*	LAN_ADMIN subnets	*	*	none		
☐		0/0 B	IPv4 TCP	LAN_EMP subnets	*	192.168.40.10	80 (HTTP)	*	none	Accès Web Server HTTP depuis LAN_EMP	
☐		0/0 B	IPv4 TCP	LAN_EMP subnets	*	192.168.40.10	443 (HTTPS)	*	none	Accès Web Server HTTPS depuis LAN_EMP	
☐		0/0 B	IPv4 *	LAN_EMP subnets	*	DMZ subnets	*	*	none		
☐		0/0 B	IPv4 *	LAN_EMP subnets	*	*	*	*	none		

Protocole	Source	Destination / Port	Action / Description
IPv4 TCP [BLOCK]	LAN_EMP subnets	This Firewall : 80	Blocage accès pfSense HTTP
IPv4 TCP [BLOCK]	LAN_EMP subnets	This Firewall : 443	Blocage accès pfSense HTTPS
IPv4 TCP	LAN_EMP subnets	192.168.40.14 : 2222	Accès SSH vers Bastion
IPv4 TCP	LAN_EMP subnets	* : 443 (HTTPS)	Navigation HTTPS
IPv4 UDP	LAN_EMP subnets	* : 53 (DNS)	Résolution DNS
IPv4 UDP	LAN_EMP subnets	* : 123 (NTP)	Synchronisation horloge

Protocole	Source	Destination / Port	Action / Description
IPv4 * [BLOCK]	LAN_EMP subnets	LAN_SRV subnets	Isolation : accès serveurs interdit
IPv4 * [BLOCK]	LAN_EMP subnets	LAN_ADMIN subnets	Isolation : accès admin interdit
IPv4 TCP	LAN_EMP subnets	192.168.40.10 : 80	Accès Web SRV HTTP
IPv4 TCP	LAN_EMP subnets	192.168.40.10 : 443	Accès Web SRV HTTPS
IPv4 * [BLOCK]	LAN_EMP subnets	DMZ subnets	Isolation DMZ
IPv4 * [BLOCK]	LAN_EMP subnets	*	Blocage du reste

1.3 Interface LAN_SRV

Le réseau serveur est isolé d'Internet et des autres zones. Les règles autorisent les échanges nécessaires au fonctionnement des services (HTTPS, DNS, NTP). Tout accès direct depuis ou vers les LAN employés, admin et DMZ est bloqué.

Rules (Drag to Change Order)											
	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
		0/0 B	IPv4 TCP	LAN_SRV subnets	*	This Firewall (self)	80 (HTTP)	*	none		
		0/0 B	IPv4 TCP	LAN_SRV subnets	*	This Firewall (self)	443 (HTTPS)	*	none		
		0/0 B	IPv4 TCP	LAN_SRV subnets	*	*	443 (HTTPS)	*	none		
		0/0 B	IPv4 TCP	LAN_SRV subnets	*	*	53 (DNS)	*	none		
		0/0 B	IPv4 TCP	LAN_SRV subnets	*	*	123 (NTP)	*	none		
		0/0 B	IPv4 *	LAN_SRV subnets	*	LAN_EMP subnets	*	*	none		
		0/0 B	IPv4 *	LAN_SRV subnets	*	DMZ subnets	*	*	none		
		0/0 B	IPv4 *	LAN_SRV subnets	*	LAN_ADMIN subnets	*	*	none		
		0/0 B	IPv4 *	LAN_SRV subnets	*	*	*	*	none		

Protocole	Source	Destination / Port	Action / Description
IPv4 TCP [BLOCK]	LAN_SRV subnets	This Firewall : 80	Blocage accès pfSense HTTP
IPv4 TCP [BLOCK]	LAN_SRV subnets	This Firewall : 443	Blocage accès pfSense HTTPS
IPv4 TCP	LAN_SRV subnets	* : 443 (HTTPS)	Mises à jour et services externes
IPv4 UDP	LAN_SRV subnets	* : 53 (DNS)	Résolution DNS
IPv4 UDP	LAN_SRV subnets	* : 123 (NTP)	Synchronisation horloge
IPv4 * [BLOCK]	LAN_SRV subnets	LAN_EMP subnets	Isolation employés
IPv4 * [BLOCK]	LAN_SRV subnets	DMZ subnets	Isolation DMZ
IPv4 * [BLOCK]	LAN_SRV subnets	LAN_ADMIN subnets	Isolation admin
IPv4 * [BLOCK]	LAN_SRV subnets	*	Blocage du reste

1.4 Interface DMZ

La DMZ héberge les services exposés (Web Server, Bastion SSH). Elle peut communiquer avec le LAN_SRV uniquement via SSH du Bastion vers le serveur BD (port 22). Tout accès direct vers les réseaux internes depuis la DMZ est bloqué.

Rules (Drag to Change Order)											
	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
☐	0/0 B	IPv4 TCP	DMZ subnets	*	This Firewall (self)	80 (HTTP)	*	none			
☐	0/0 B	IPv4 TCP	DMZ subnets	*	This Firewall (self)	443 (HTTPS)	*	none			
☐	0/0 B	IPv4 TCP	192.168.40.14	*	192.168.20.10	22 (SSH)	*	none		SSH Bastion to SRV-BD	
☐	0/0 B	IPv4 TCP	DMZ subnets	*	*	443 (HTTPS)	*	none			
☐	0/0 B	IPv4 UDP	DMZ subnets	*	*	53 (DNS)	*	none			
☐	0/0 B	IPv4 UDP	DMZ subnets	*	*	123 (NTP)	*	none			
☐	0/0 B	IPv4 *	DMZ subnets	*	LAN_ADMIN subnets	*	*	none			
☐	0/0 B	IPv4 *	DMZ subnets	*	LAN_EMP subnets	*	*	none			
☐	0/0 B	IPv4 *	DMZ subnets	*	LAN_SRV subnets	*	*	none			
☐	0/0 B	IPv4 *	DMZ subnets	*	*	*	*	none			

Protocole	Source	Destination / Port	Action / Description
IPv4 TCP [BLOCK]	DMZ subnets	This Firewall : 80	Blocage accès pfSense HTTP
IPv4 TCP [BLOCK]	DMZ subnets	This Firewall : 443	Blocage accès pfSense HTTPS
IPv4 TCP	192.168.40.14 (Bastion)	192.168.20.10 : 22 (SSH)	SSH Bastion → Serveur BD
IPv4 TCP	DMZ subnets	* : 443 (HTTPS)	Accès HTTPS externe (mises à jour)
IPv4 UDP	DMZ subnets	* : 53 (DNS)	Résolution DNS
IPv4 UDP	DMZ subnets	* : 123 (NTP)	Synchronisation horloge
IPv4 * [BLOCK]	DMZ subnets	LAN_ADMIN subnets	Blocage DMZ → admin
IPv4 * [BLOCK]	DMZ subnets	LAN_EMP subnets	Blocage DMZ → employés
IPv4 * [BLOCK]	DMZ subnets	LAN_SRV subnets	Blocage DMZ → serveurs (hors règle 3)
IPv4 * [BLOCK]	DMZ subnets	*	Blocage du reste

1.5 NAT – Port Forward

Une règle NAT Port Forward redirige le trafic entrant sur le port 2222 (WAN) vers le Bastion SSH en DMZ. Cela permet l'administration à distance sans exposer directement les adresses internes. La capture ci-dessous montre la règle configurée :

Firewall / NAT / Port Forward										
Port Forward 1:1 Outbound NPt										
Rules										
☐	Interface	Protocol	Source Address	Source Ports	Dest. Address	Dest. Ports	NAT IP	NAT Ports	Description	Actions
☐  	WAN	TCP	*	*	WAN address	2222	192.168.40.14	2222		  

Les règles WAN autorisent uniquement le trafic généré par le NAT ci-dessus. Tout autre trafic entrant depuis l'extérieur est bloqué par défaut.

Rules (Drag to Change Order)											
	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
☐  	0/0 B	IPv4 TCP	*	*	192.168.40.14	2222	*	none		NAT	    

2. Journalisation

La journalisation est activée sur l'ensemble des règles de chaque interface (LAN_ADMIN, LAN_EMP, LAN_SRV, DMZ et WAN). Elle permet de tracer les événements réseau, de détecter des comportements anormaux et de constituer des preuves en cas d'incident.

2.1 Éléments journalisés

Les événements suivants sont enregistrés :

- Toutes les connexions bloquées sur l'interface WAN
- Les tentatives de connexion SSH vers le Bastion depuis l'extérieur
- Les accès aux interfaces d'administration (LAN_ADMIN)
- Les connexions établies entre la DMZ et le LAN_SRV
- Les changements de configuration du pare-feu (authentification administrateur)

Paramètre	Configuration
Interfaces journalisées	WAN, LAN_ADMIN, LAN_EMP, LAN_SRV, DMZ
Niveau de log	Connexions bloquées + connexions établies sur règles critiques
Protocole de transfert	Syslog UDP 514 vers serveur Linux interne
Rétention locale (pfSense)	Tampon circulaire (500 entrées par défaut)
Rétention distante	30 jours minimum sur serveur Syslog Linux
Consultation	Status > System Logs > Firewall (interface Web pfSense)

3. Politique de mots de passe

Une politique stricte de mots de passe est appliquée à l'ensemble des comptes du système d'information. Elle vise à réduire les risques liés aux accès non autorisés et aux attaques par force brute.

3.1 Règles applicables

Critère	Exigence
Longueur minimale	12 caractères
Majuscules	Au moins 1 lettre majuscule
Minuscules	Au moins 1 lettre minuscule
Chiffres	Au moins 1 chiffre
Caractères spéciaux	Au moins 1 caractère spécial (ex. : !, @, #, \$, &, *)
Réutilisation	Interdiction de réutiliser les 5 derniers mots de passe
Durée de validité	90 jours maximum — renouvellement obligatoire
Verrouillage de compte	Blocage après 5 tentatives échouées consécutives

3.2 Comptes définis et conformité

Les comptes ci-dessous ont été définis pour l'infrastructure. Leurs mots de passe respectent l'intégralité de la politique en vigueur.

Équipement	Identifiant	Mot de passe	Conformité
Firewall (pfSense)	admin	WGZiK\$SgV&9R	✓ Conforme
Poste Admin (Ubuntu)	administrateur	427#VXh&a4s7	✓ Conforme
Client-01 (CLI-01)	sami	\$kqEqBEJ7HfD	✓ Conforme

Note : Les mots de passe ne doivent jamais être transmis en clair. Ils sont stockés de manière sécurisée et ne doivent pas être partagés entre utilisateurs.

4. Justification des choix de sécurité

4.1 Refus par défaut (Default Deny)

L'ensemble des interfaces applique un principe de refus par défaut. Toute communication non explicitement autorisée est bloquée, minimisant la surface d'attaque.

4.2 Isolation des zones réseau

La segmentation en zones distinctes (LAN_ADMIN, LAN_EMP, LAN_SRV, DMZ) garantit qu'une compromission dans une zone ne peut se propager aux autres sans passer par le pare-feu.

4.3 Accès administrateur restreint

Le LAN_ADMIN est le seul réseau disposant de droits d'accès étendus. Toute connexion SSH directe depuis l'extérieur passe obligatoirement par le Bastion SSH en DMZ.

4.4 Journalisation systématique

La journalisation activée sur toutes les interfaces pfSense assure une traçabilité complète des événements réseau. En cas d'incident, les journaux fournissent les informations nécessaires à l'analyse.

4.5 Politique de mots de passe robuste

La politique appliquée garantit une résistance aux attaques par force brute. Le renouvellement périodique, l'interdiction de réutilisation et le verrouillage après 5 tentatives limitent les risques de compromission.